

you can rely on the *Disallow* feature of *robots.txt*, because some search engines still crawl unwanted pages/directories of the server.

Tools of the secure trade

1. Goolag, an automated Google search application, helps you find some impressive information about your Web application. Download it along with its documentation, from <http://www.goolag.org/download.html>.
2. Gooscan is another tool that automates queries against Google search appliances but these particular queries are designed to find potential vulnerabilities on Web pages. Download it from <http://avondale.google.net/db/dl/http://indianz.ch/tools/scan/>.

Information leakage

Information leakage occurs when a website reveals sensitive data which may aid an attacker in exploiting the system. It does not necessarily represent a security breach, but it provides the attacker information that may be useful for future exploitation. There are many ways of forcing a Web application to leak this type of information.

comments

Website programmers often leave comments in HTML source code. These are mainly for their self-reference, and sometimes for other programmers to see. However, often these comments help attackers in understanding the target better. For example, look at the HTML code below:

```
<TABLE border="0" cellPadding="0"
cellSpacing="0" height="59" width="591">
<TBODY>
<TR>
<!--If the image files are missing, restart
ZBEAST -->
<TD bgColor="#ffffff" colSpan="5"
height="17" width="587">&nbsp;  </TD>
```

Here we see a comment left by the programmer indicating what one

should do if image files do not show up. The key information here is the host name of the server, which is mentioned explicitly in the code, 'ZBEAST'.

JavaScript code

Parts of JavaScript code, especially those dealing with data validation, can reveal a lot of information about application business rules. Often, programmers implement data validation on the client side itself, thinking that this will reduce server-side load. This is a mistake.

Tools' comments and metadata

Tools that are used to create Web pages (either server-side or client-side) also often leave comments in the code, which could include paths in the file system.

WebDAV

Web Distributed Authoring and Versioning (WebDAV) is an extension of the HTTP protocol. It consists of several new request methods that are added on top of HTTP to allow functionality, such as editing and managing files stored on WWW servers even from remote systems. If it is enabled by default on a website, WebDAV will allow anyone to enumerate files on the site, even with all directory indexes in place and directory listings turned off.

PROPFIND (an HTTP method used by WebDAV) is used to retrieve properties (stored as XML) from a resource, and also allows one to retrieve the collection structure (a.k.a. directory hierarchy) of a remote system. This can be used by attackers as shown below, using telnet to connect to www.example.com:

```
$ telnet example.com 8080
Trying 217.160.182.153...
Connected to example.com.
Escape character is '^]'.
PROPFIND / HTTP/1.1
Depth: 1
```

The above process will reveal the contents of the Web server root folder.

Users browsing normally would get served *index.html*, but when using WebDAV, the attacker can reveal many secret files.

Verbose error messages

These are messages which are mainly responses to an invalid query. A prominent example is the error message associated with SQL queries. SQL injection attacks typically require the attacker to have prior knowledge of the structure or format used to create SQL queries on the site. The information leaked by a verbose error message can provide the attacker with crucial information on how to construct valid SQL queries for the back-end database. (For information on SQL injection, refer to Part 1 of this series.) The following error message was returned by placing an apostrophe into the username field of a login page:

```
An Error Has Occurred.
Error Message:
System.Data.OleDb.OleDbException:
Syntax error (missing
operator) in query expression
'username = ''' and password =
'g'''. at
System.Data.OleDb.OleDbCommand.
ExecuteCommandTextWithErrorHandling (
Int32 hr) at
System.Data.OleDb.OleDbCommand.
ExecuteCommandTextForSingleResult
(tagDBPARAMS dbParams, Object&
commandResult) at
```

In the first error statement, a syntax error is reported. The error message reveals the query parameters that are used in the SQL query: *username and password*. The leaked information here is the missing link for an attacker to begin to construct SQL injection attacks against the site.

A common error that we can see during our search is *HTTP 404 Not Found*. Often, this error code provides useful details about the underlying Web server and associated components. For example: